

THREAT ADVISORY



**VULNERABILITY
REPORT**

**Zero-Day Remote Code Execution Vulnerability in
Zimbra Collaboration Suite**

Date of Publication

October 10, 2022

Admiralty Code

A1

TA Number

TA2022217

Summary

The active exploitation of an unpatched CVE-2022-41352 remote code execution (RCE) vulnerability found in the Zimbra Collaboration Suite (ZCS). It empowers attackers to upload arbitrary files and execute malicious operations on vulnerable hosts. The bug exists as a result of amavis insecure fallback to utilizing cpio to extract files if the pax package is not installed on the system.

CVE Table

CVE	NAME	PATCH
CVE-2022-41352	Arbitrary file overwrite	

Potential MITRE ATT&CK TTPs

TA0042 Resource Development	T1584 Compromise Infrastructure	T1586 Compromise Accounts	TA0004 Privilege Escalation
T1548 Abuse Elevation Control Mechanism	T1543 Create or Modify System Process	TA0008 Lateral Movement	T1210 Exploitation of Remote Services
TA0040 Impact	T1565 Data Manipulation		

Technical Details

#1

The Zero-day vulnerability is a remote code execution weakness triggered by the incorrect use of the cpio utility, specifically by Zimbra's antivirus engine Amavis, scanning inbound emails with the insecure cpio utility. CVE-2022-41352 is nearly identical to (CVE-2022-30333) a path traversal flaw in the Unix version of RARlab's unRAR utility which came to light earlier this June with the exception of a different file type .cpio and .tar rather than .rar

#2

To exploit this flaw, an attacker would send a .cpio, .tar, or.rpm email to a vulnerable server, which would subsequently overwrite system files with the permission of the running Zimbra server including the Zimbra webroot. The recommended workaround is to install the pax archive utility, then reboot Zimbra, while monitoring for additional Zimbra software updates.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-41352	Zimbra Collaboration Suite 9.0.0 & 8.8.15	cpe:2.3:a:zimbra:collaboration:8.8.15:-:*:*:*:*:* cpe:2.3:a:zimbra:collaboration:9.0.0:-:*:*:*:*:*	CWE-434

References

<https://www.rapid7.com/blog/post/2022/10/06/exploitation-of-unpatched-zero-day-remote-code-execution-vulnerability-in-zimbra-collaboration-suite-cve-2022-41352/>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

October 10, 2022 • 3:26 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com